
Cloud Security

Learning Objectives

After reading this chapter, you will be able to

- Assess data security in the Cloud
- Describe security management in the Cloud
- Compare and contrast IaaS, PaaS, SaaS security in the Cloud deployments.

Cloud computing security or, in other words, Cloud security alludes to a wide arrangement of approaches, advances and controls conveyed to ensure information, applications and the related framework of Cloud computing. It is a sub-domain of computer security, network security, and, all the more extensively, data security. Cloud computing storage capability provides clients with abilities to store and procedure their information in data centers. Organizations utilize the Cloud in a wide range of service models (for example, SaaS, PaaS and IaaS) and deployment models (private, hybrid, public and community).

Security concerns related with Cloud computing fall into two categories: security issues faced by Cloud providers (organizations providing software, platform-, or infrastructure-as-a-service via the Cloud) and security issues faced by their clients (organizations or associations who have applications or stored information on the Cloud). The responsibilities are shared among them. The providers must guarantee that their services are secure and that their customer's information and applications are protected, while the client must take measures to support security measures (such as usage of strong passwords).

Preliminaries

The following are some of terms and terminologies given here for easier understanding in the remaining part of this chapter.

Confidentiality is the prevention of the intentional or unintentional unauthorized disclosure of contents. Loss of confidentiality can occur in many ways. For example, loss of confidentiality can occur through the intentional release of private company information or through a misapplication of network rights. Consider the confidentiality of data stored by a distributed storage system. If

stored resources are served to any requesting entity, the confidentiality of data intended to be accessible by a specific subset of users cannot be guaranteed.

Integrity is the assurance that the message sent is the message received and that the message is not purposefully or unexpectedly changed. Loss of trustworthiness can happen through a purpose to change data. Consider the trustworthiness of information stored in a Cloud. On the off chance that both system components and consumers acknowledge control messages and information moved aimlessly, an attacker might impact either the server or the customer to acknowledge invalid information by modifying the stream of information sent.

Availability alludes to the components that create reliability and stability in systems and frameworks. It guarantees that availability is open when required, permitting approved clients to get the system or frameworks. The performance or scalability remains a challenge inspite of the fact that secure access control, storage, and transmission may permit an appropriate storage framework to protect the secrecy of information.

With the appropriation of open Cloud benefits, a huge part of network, system, framework, applications and information will move under third-party control. The Cloud administrations conveyance model will make islands (Clouds) of virtual perimeters just as a security model with obligations shared between the client and the Cloud service provider (CSP).

11.1 Data Security

Data security becomes very significant for data that is communicated from one device to another. It is referred to as data-in-transit. This is an information security concept that is used to identify data that requires encryption. The following are common examples of data in transit.

Public Networks: Transfer of data over public networks such as the Internet. For example, an app. on a mobile phone connects to a banking service to request a transaction. Such data is typically encrypted using protocols such as Hyper Text Transfer Protocol (HTTP).

Private Networks: Transfer of data over a secured private network such as an local area network set up for an office location. The principle of defense in depth suggests that systems and applications should not trust that a network

has been properly secured. As such, it is common to apply the same level of encryption for private networks as public networks.

Local Devices: Transfer of data between local devices such as computers, data storage devices and peripherals. Such data could be intercepted by the medium that is used for the transfer. For example, a Universal Serial Bus (USB) cord that connects a data storage device and a computer could potentially record or transmit the data.

Data-in-transit is defined into two categories: (i) information that flows over the public or untrusted network such as the Internet, and (ii) data that flows in the confines of a private network such as a corporate or enterprise Local Area Network (LAN). With regard to data-in-transit, the primary risk is in not using a vetted encryption algorithm. Although this is obvious to information security professionals, it is not common for others to understand this requirement when using a public Cloud, regardless of whether it is IaaS, PaaS, or SaaS.

In addition to the security of data, customers should also be concerned about what data the provider collects and how the Cloud Service Provider (CSP) protects that data. Specifically with regard to customer's data, what metadata does the provider have about data, how is it secured, and what access does the customers have to that metadata? As the volume of data with a particular provider increases, so does the value of that metadata.

There are numerous security issues for Cloud computing as it encompasses many technologies including networks, databases, operating systems, virtualization, resource scheduling, transaction management, load balancing, concurrency control and memory management. For example, the network that interconnects the systems in a Cloud has to be secure and mapping the virtual machines to the physical machines has to be carried out securely. Data security involves encrypting the data as well as ensuring that appropriate policies are enforced for data sharing. Some of the significant security concerns in a Cloud computing environment are discussed below.

Data Transmission: It is the process of sending digital or analog data over a communication medium to one or more computing, network, communication or electronic devices. It enables the transfer and communication of devices in a point-to-point, point-to-multipoint and multipoint-to-multipoint environment.

Virtualization Security: Virtualization security is the collective measures, procedures and processes that ensure the protection of a virtualization infrastructure/environment. It addresses the security issues faced by the components of a virtualization environment and methods through which it can be mitigated or prevented.

Network Security: It is an organization's strategy and provisions for ensuring the security of its assets and all network traffic. Network security is manifested in an implementation of security hardware and software.

Data Integrity: It is the aspect of information technology (IT) that deals with the ability an organization or individual has to determine what data in a computer system can be shared with third parties.

Data Privacy: It is a fundamental component of information security. In its broadest use, "data integrity" refers to the accuracy and consistency of data stored in a database, data warehouse, data mart or other construct.

Data Location: Cloud storage is a model of computer data storage in which the digital data is stored in logical pools. The physical storage spans multiple servers (sometimes in multiple locations), and the physical environment is typically owned and managed by a hosting company.

Data Availability: It is a term used by some computer storage manufacturers and storage service providers (SSPs) to describe products and services that ensure that data continues to be available at a required level of performance in situations ranging from normal through "disastrous".

In the next section, we discuss encryption techniques in Cloud.

11.2 Encryption Techniques in Cloud

Cloud encryption is the transformation of a Cloud service customer's data into ciphertext. Cloud encryption is a service offered by Cloud storage providers whereby data, or text, is transformed using encryption algorithms and is then placed on a storage Cloud. Some of the important encryption techniques are discussed below.

1. Attribute-based encryption (ABE): It is a type of public-key encryption in which the secret key of a user and the ciphertext are dependent upon attributes (e.g. the country in which he lives, or the kind of subscription he has). In such a system, the decryption of a ciphertext is possible only if the set of attributes of the user key matches the attributes of the ciphertext. It is further categorized as follows:
 - Ciphertext-policy ABE (CP-ABE): In the CP-ABE, the encryptor controls access strategy. The main idea of CP-ABE is focused on the design of the access structure.

- **Key-policy ABE (KP-ABE):** In the KP-ABE, attribute sets are used to describe the encrypted texts and the private keys are associated to specified policy that users will have.
- 2. **Fully homomorphic encryption (FHE):** It allows computations on encrypted data, and also allows computing sum and product for the encrypted data without decryption.
- 3. **Searchable encryption (SE):** It is a cryptographic system which offer secure search functions over encrypted data. SE schemes can be classified into two categories: SE based on secret-key (or symmetric-key) cryptography, and SE based on public-key cryptography. In order to improve search efficiency, symmetric-key SE generally builds keyword indexes to answer user queries.

11.2.1 Decentralized Key-Policy Attribute-based Encryption

In a decentralized scheme, it is not necessary to maintain a fixed number of attribute authorities. Any attribute authority can join and/or leave the system at any time without rebooting the system. First of all, we will look at the sub-modules required and security game followed by the privacy-preserving decentralized KP-ABE.

Sub-modules: The module consists of five sub-modules namely global setup, authority setup, key issuing, encryption and decryption. Let us briefly explain the functionalities of each sub-modules.

Global Setup: This module takes a security parameter as input and output system parameters. These system parameters can be used by authorities who join the system.

Authority Setup: Each attribute authority uses the system parameters obtained from the global setup to generate public and private keys for the attributes it maintains.

Key Issuing: User and attribute authority interact via anonymous key issuing protocol in order to determine a set of attributes belongs to the user. Then attribute authority generates decryption credentials for those attributes and send them to the user.

Encryption: The encryption algorithm takes a set of attributes maintained by attribute authority and the data as input. Then it outputs the ciphertext of the data.

Decryption: The decryption algorithm takes the decryption credentials received from attribute authorities and the ciphertext as input. The decryption will be successful if and only if the user attributes satisfy the access structure.

11.2.2 Security Game

In order to avoid the security vulnerabilities, ABE schemes is proven to be secure against the selective identity (ID) model. In the selective ID model, the adversary provides the identities of the attribute authorities (challenge identities) he wishes to challenge the challenger with. Then challenger (i.e., the system) generates necessary parameters corresponding to the challenge identities and sends them to the adversary. Then the adversary is allowed to make secret queries about the challenge identities. If the adversary cannot decrypt the encrypted message at the end with non-negligible advantage then the scheme discussed here is secure against the selective ID model. Formally, this is represented by a game between the adversary and the challenger. Adversary sends a list of attribute sets and attribute authorities including corrupted authorities to the challenger. Now the challenger generates public and private keys corresponding to the attributes and authorities provided by the adversary. Challenger provides public and private keys corresponding to the corrupted authorities to the adversary while only public keys corresponding to the remaining authorities to the adversary.

Secret Key Queries

- The adversary is allowed to make any number of secret key queries as he wants against the attribute authorities.
- However, the only requirement is that for each user, there must be at least one non corrupted attribute authority from which the adversary can get insufficient number of secret keys.

Challenge

- The adversary sends two messages m_0 and m_1 to the challenger in plain domain.
- Now the challenger randomly chooses one of the messages and encrypt it and send the ciphertext to the adversary.

More Secret Key Queries

- The adversary is allowed to make more secret key queries as long as he satisfies the requirement given earlier.

Guess

- Now the adversary guesses which message was encrypted by the challenger.
- The adversary is said to be successful if he guesses the correct message with probability $\frac{1}{2} + \epsilon$ whereby ϵ is a non-negligible function.

11.2.3 Fully Homomorphic Encryption (FHE)

In FHE, the system involves multiple parties playing three key roles in the secure computation, the *users* who outsource the computation to a remote party (Cloud), with their secret data protected from unauthorized interrogation; the *homomorphic computation (HC) nodes* provided by the Cloud services using unprotected CPU, GPU or FPGA-based instances.

The data flow among participating parties with the FHE system is simple. The users first verify the configuration of the Cloud through remote attestation, and establish the shared secret key with the bootstrapping nodes. Afterwards, the users provision their encryption parameters as well as the secret and public keys to the bootstrapping nodes through the established secret channel. The user's data encrypted under the homomorphic secret key is sent to the HC nodes to perform homomorphic computations. If the computation requires private data from multiple users, each user sends the data encrypted using their own key to the HC nodes.

When bootstrapping is needed in the homomorphic computation, the current intermediate ciphertext is sent from the HC nodes to the bootstrapping nodes. The bootstrapping nodes, running inside a secure enclave, first decrypt the ciphertext, then re-encrypt it using the secret key and send the refreshed ciphertext back to the HC nodes. It removes the noise in the ciphertext, and thus enables further homomorphic computation by the HC nodes. After the whole homomorphic computation is completed, the ciphertext is sent from the HC node back to the users. The users decrypt the ciphertext to retrieve the computation result.

Homomorphic encryption can be used for privacy-preserving outsourced storage and computation. This allows data to be encrypted and out-sourced to commercial Cloud environments for processing, all while encrypted. In highly regulated industries, such as health care, homomorphic encryption can be used to enable new services by removing privacy barriers inhibiting data sharing. For example, predictive analytics in health care can be hard to apply due to medical data privacy concerns, but if the predictive analytics service provider can operate on encrypted data instead, these privacy concerns are diminished.

11.2.4 Searchable Encryption

Searchable encryption works by exposing segment of information of a context that can be used to identify a context. For example, if there is post about electoral debate in BBC, transcript of the debate can be easily identified by "electoral debate", "BBC" and such keywords. They along with date may be sufficient to find that specific manuscript among thousand other.

Searchable encryption enables identification of an encrypted content based on some segment of information available about the content without exposing the content itself. In this example, those key words would be able to find the transcript of electoral debate but won't be enough to get the actual content. So the content owner would encrypt the data with a private key and share the keyword encrypted with the public key of the search provider, or a shared secret key that is shared with the provider as well. Now once the search query comes, the provider would open the envelop of the keyword collection and matches the search. Once the match is found it would establish the connection between the content owner and the requester. Then the requester and content owner can negotiate the terms of accessing the private content without the presence of the search provider.

Let's see another example of searchable encryption. Suppose Alice wants to forward all the mails marked "Urgent" to John while she is away on her vacation. Now Bob sends an encrypted email to Alice encrypted with Alice's public Key. But the gateway provider has no way of knowing whether to route the mail to John if it is marked "Urgent." Then John extracts the keyword urgent, performs searchable encryption or Public Key Encryption with keyword search on the extracted keyword and send the data to gateway. The gateway can now decrypt the keyword list and route the message to John.

11.2.5 Web Processing Service (WPS)

Towards implementing a Web Processing Services (WPS) on a Cloud, the Open Geospatial Consortium (OGC) WPS defines a standardized interface that facilitates the publishing of geospatial processes so that geoprocessing services can be delivered over the Internet (OGC 2007). Geospatial processing refers to the manipulation of geographic information, ranging from simple feature overlays and geocoding to raster processing and advanced climate modelling.

There are many advantages of deploying a geoprocessing service in a Cloud. For example, a compute intensive WPS, such as one that does climate modelling, could benefit from the scalability of the resources in a Cloud or a WPS that suddenly becomes popular (e.g. one that does polygon intersections) could benefit from the user scalability provided by the Cloud. While geoprocessing services probably stand to benefit most from processing (resource) scalability, implementations of OGC's Web Feature Service (WFS) stand to benefit from the scalability of user requests that a Cloud provides. A WPS can be deployed in any of the three service models of a Cloud, namely IaaS, PaaS, or SaaS.

In an IaaS Cloud, the user has full control over resources, but virtualization happens at a low level, and the user therefore has the responsibility to address

many security risks. Deploying geoprocessing on an IaaS Cloud makes sense if an organisation needs to deploy a variety of WPSs and has the required human resources to administer the IaaS Cloud.

In a PaaS Cloud, virtualization happens at a higher level of abstraction, and therefore, some of the development challenges of building scalable applications are handled by the Cloud platform. In a WPS, input data are supplied either embedded in the execute request or referenced as a web accessible resource. Both ways are possible in a PaaS Cloud because they do not rely on accessing files on a local file system. However, the WPS source code cannot create any temporary files that could be required during processing. Instead, such data have to be stored temporarily in Cloud database tables.

Google App Engine (GAE) provides authentication through its web portal and single sign-on authentication for first-time registration. Single sign-on allows a generated password to be used only once. Upon sign up to use GAE and request for a domain name, a password is generated and sent to the user's cellular phone. This generated password can then be used to activate the user's account, after which the password cannot be used again.

All of the Clouds allow Secure Sockets Layer (SSL) encryption. SSL is one of the most widely used communication protocols on the Internet. It provides encrypted communication between a client and server, as well as optional client and server authentication. While SSL provides network communication encryption, data encryption is provided by programming libraries and database management systems.

In the next section, we discuss Infrastructure Security.

11.3 Infrastructure Security

Information security, sometimes shortened to InfoSec, is the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information. The information or data may take any form, e.g. electronic or physical. Information security's primary focus is the balanced protection of the Confidentiality, Integrity and Availability of data (also known as the CIA triad) while maintaining a focus on efficient policy implementation, all without hampering organization productivity. This is largely achieved through a multi-step risk management process that identifies assets, threat sources, vulnerabilities, potential impacts, and possible controls, followed by assessment of the effectiveness of the risk management plan.

To properly understand the threats that Cloud computing presents to the computing infrastructure, it is important to understand communications security techniques to prevent, detect, and correct errors so that integrity, availability, and the confidentiality of transactions over networks may be maintained. This includes the following:

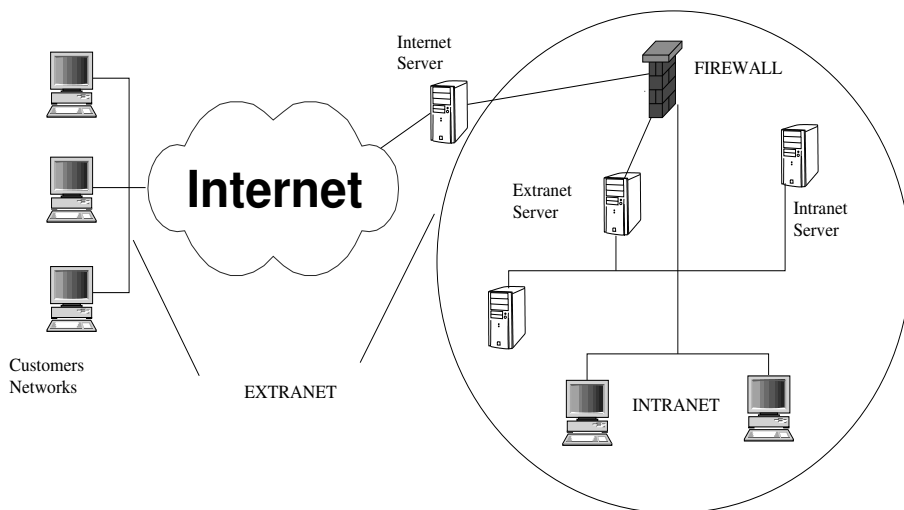
- Communications and network security as it relates to voice, data, multimedia and facsimile transmissions in terms of local area, wide area and remote access networks
- Internet/intranet/extranet in terms of firewalls, routers, gateways and various protocols

11.3.1 Infrastructure Security: The Network Level

When looking at the network level of infrastructure security, it is important to distinguish between public Clouds and private Clouds. With private Clouds, there are no new attacks, vulnerabilities, or changes in risk specific to this topology that information security personnel need to consider. Although the organization's IT architecture may change with the implementation of a private Cloud, the current network topology will probably not change significantly. If we have a private extranet, an intranet that can be partially accessed by authorized outside users, enabling businesses to exchange information over the Internet in a secure way, for practical purposes we probably have the network topology for a private Cloud in place already. The security considerations we have today apply to a private Cloud infrastructure, too. And the security tools we have in place (or should have in place) are also necessary for a private Cloud and operate in the same way.

Figure 11.1 shows the topological similarities between a secure extranet and a private Cloud. Internet, intranet and extranet are the networks of computer. Internet is an open to all network that can be accessed by anyone in the world with an Internet connected device. Intranet is the computer network for groups containing small members and can be accessed by these members only. These network are used in business fields as one member has to share files and other docs to other members within a group. It is also used for networking within building or home.

Extranet is computer network used by people of particular network with a login identity and password. These are sometimes used by two or more departments to communicate with each other or by some companies to handle account for particular customers. There are three significant risk factors in this usecase, given as follows.

**FIGURE 11.1**

Similarities between a secure extranet and a private Cloud

Ensuring the confidentiality and integrity of our organization's data-in-transit to and from our public Cloud provider: Some resources and data previously confined to a private network are now exposed to the Internet, and to a shared public network belonging to a third-party Cloud provider. Although use of HTTPS (instead of HTTP) would have mitigated the integrity risk, users not using HTTPS (but using HTTP) did face an increased risk that their data could have been altered in transit without their knowledge.

Ensuring proper access control (authentication, authorization and auditing) to whatever resources we are using at your public Cloud provider: Since some subset of these resources (or maybe even all of them) is now exposed to the Internet, an organization using a public Cloud faces a significant increase in risk to its data. The ability to audit the operations of your Cloud provider's network (let alone to conduct any realtime monitoring, such as on your own network), even after the fact, is probably non-existent.

Ensuring the availability of the Internet-facing resources in a public Cloud that are being used by our organization, or have been assigned to our organization by public Cloud providers: Reliance on network security has increased because an increased amount of data or an increased number of organizational personnel now depend on externally hosted devices to ensure the availability of Cloud-provided resources.

Consequently, the three risk factors enumerated in the preceding section must be acceptable to an organization. Misconfiguration may still affect the availability of your Cloud-based resources.

According to a study presented to the North American Network Operators Group (NANOG) in February 2006, several hundred such misconfigurations occur per month. Probably the best known example of such a misconfiguration mistake occurred in February 2008 when Pakistan Telecom made an error by announcing a dummy route for YouTube to its own telecommunications partner, PCCW, based in Hong Kong. The intent was to block YouTube within Pakistan because of some supposedly blasphemous videos hosted on the site. The result was that YouTube was globally unavailable for two hours.

11.3.2 Trust Zones (TZ) Scheme Infrastructure Security

The vulnerability of Cloud Computing Systems (CCSs) to advanced persistent threats (APTs) is a significant concern to government and industry. Cloud Service Provider (CSP) personnel with physical access to the CSP datacenter can breach security controls by direct access to physical machines. However, the large number of machines complicates the task. Precision requires the attacker first identify the hardware hosting the target data. The CSP insider cannot make physical contact with every machine in the datacenter, but he has several methods to locate the machine hosting the agency Trust Zones (TZs) VMs.

TZs is defined as a combination of network segmentation and identity and access management (IAM) controls. These define physical, logical, or virtual boundaries around network resources. Cloud TZs can be implemented using physical devices, virtually using virtual firewall and switching applications, or using both physical and virtual appliances. The first is to enumerate all of the Agency's live VMs. CSP management servers hold such data. A CSP sys-admin will have access to this data.

The list of agency VMs might be very large. The attacker must reduce the list so he can visit each machine. Information that can help narrow the list is configuration data. This includes security group and other tenant created configurations that reveal the topology of the tenants resources in the Cloud, specific services that can be assumed based on specific ports that are open, identity and access management data that shows which tenant users have CSP accounts and what they are allowed to do with specific resources, tenant naming conventions for their machine images or instances, and relative memory, disk, CPU and I/O sizing of various instances. These steps are likely to identify, for example, large machines, which host web server, file share, or

database processes, and those that have limited access.

Once the CSP insider knows which machines to visit, he must map these to the datacenter layout. Datacenters that are segmented or compartmentalized, or keep access to physical and logical maps separate, will complicate the task. In contrast, datacenters that have a single point of entry will make this attack easier.

The malware injected via physical access provides a breach point for the attacker. The breach itself can provide network access and elevated privileges on the HV hosting the target VM. By beaconing to known attacker control nodes, the attacker can establish a link to control the execution of the rest of the attack.

11.4 PaaS Application Security

PaaS vendors broadly fall into the following two major categories, i.e., software vendors (e.g., Bungee, Etelos, GigaSpaces, Eucalyptus) and CSPs (e.g., Google App Engine, Salesforce.com's Force.com, Microsoft Azure, Intuit QuickBase).

Organizations evaluating a private Cloud may utilize PaaS software to build a solution for internal consumption. Currently, no major public Clouds are known to be using commercial off-the-shelf or open source PaaS software such as Eucalyptus (Eucalyptus does offer a limited experimental pilot Cloud for developers at Eucalyptus.com). Therefore, given the nascent stage of PaaS deployment, it is recommended that organizations evaluating PaaS software perform a risk assessment and apply the software security standard similar to acquiring any enterprise software.

Generally speaking, PaaS CSPs (e.g., Google, Microsoft, and Force.com) are responsible for securing the platform software stack that includes the runtime engine that runs the customer applications. Since PaaS applications may use third-party applications, components, or web services, the third-party application provider may be responsible for securing their services. Hence, customers should understand the dependency of their application on all services and assess risks pertaining to third-party service providers.

Until now, CSPs have been reluctant to share information pertaining to platform security using the argument that such security information could provide an advantage for hackers. However, enterprise customers should demand transparency from CSPs and seek information necessary to perform risk

assessment and ongoing security management.

PaaS Access Control

Generally speaking, access control management in PaaS is a broad function that encompasses access requirements for your users and system administrators (privileged users) who access network, system, and application resources. The access control management functions should address questions such as assignment of entitlements to users, assignment of entitlements based on the user's job functions and responsibilities, authentication method and strength required prior to granting access to the resource, auditing and reporting to verify entitlement assignments. The aforementioned aspects of the access control domain should be addressed by organization's access policies and standards and aligned with the user's roles and responsibilities, including end users and privileged system administrators.

Hardening the Host OS for PaaS Security

Vulnerabilities inherent in the operating system of the host computer can flow upward into the virtual machine operating system. While a compromise on the VM OS would hopefully only compromise the guest domain, a compromise of the underlying host OS would give an intruder access to all services on all virtual machines hosted by the machine. Therefore, best practice hardening techniques must be implemented to maintain the security posture of the underlying technology. Some of these techniques include the following:

- Use strong passwords, such as lengthy, hard to guess passwords with letters, numbers, and symbol combinations, and change them often.
- Disable unneeded services or programs, especially networked services.
- Require full authentication for access control.
- The host should be individually firewalled.
- Patch and update the host regularly, after testing on a nonproduction unit.

Single Sign-On (SSO) Scheme for PaaS Security

Single sign-on (SSO) addresses the cumbersome situation of logging on multiple times to access different resources. When users must remember numerous passwords and IDs, they might take shortcuts in creating them that could leave them open to exploitation. In SSO, a user provides one ID and password per work session and is automatically logged on to all the required

applications. For SSO security, the passwords should not be stored or transmitted in the clear.

SSO applications can run either on a user's workstation or on authentication servers. The advantages of SSO include having the ability to use stronger passwords, easier administration of changing or deleting the passwords, and less time to access resources. The major disadvantage of many SSO implementations is that once users obtain access to the system through the initial login, they can freely roam the network resources without any restrictions.

A very popular example of SSO login is Google's implementation for their software products. Once a user is logged in to Gmail, the user automatically gains access to YouTube, Google Drive, Google Photos and other Google products.

11.5 SaaS Application Security

The SaaS model dictates that the provider manages the entire suite of applications delivered to users. Therefore, SaaS providers are largely responsible for securing the applications and components they offer to customers. Customers are usually responsible for operational security functions, including user and access management as supported by the provider. It is a common practice for prospective customers to request information related to the provider's security practices. This information should encompass design, architecture, development, black- and white-box application security testing, and release management.

Some SaaS applications, such as Google Apps, have built-in features that end users can invoke to assign read and write privileges to other users. However, the privilege management features may not be advanced, fine-grained access and could have weaknesses that may not conform to your organization's access control standard. One example that captures this issue is the mechanism that Google Docs employs in handling images embedded in documents, as well as access privileges to older versions of a document.

Evidently, embedded images stored in Google Docs are not protected in the same way that a document is protected with sharing controls. That means, if one has shared a document containing embedded images, the other person will always be able to view those images even after you've stopped sharing the document.

11.5.1 FHE Scheme for SaaS Security

Unlike the partially homomorphic encryption which allow homomorphic computation of some operations on ciphertexts (e.g., additions, multiplications, quadratic functions, etc.), fully homomorphic encryption supports arbitrary computation on ciphertexts. Such a scheme enables the construction of programs for any desirable functionality, which can be run on encrypted inputs to produce an encryption of the result. Since such a program need never decrypts its inputs, it can be run by an untrusted party without revealing its inputs and internal state.

Here is a very simple example of how a homomorphic encryption scheme might work in Cloud computing:

- Business *B* has a very important data set (VIDS) that consists of the numbers 5 and 10. To encrypt the data set, Business *B* multiplies each element in the set by 2, creating a new set whose members are 10 and 20.
- Business *B* sends the encrypted VIDS set to the Cloud for safe storage. A few months later, the government contacts Business *X* and requests the sum of VIDS elements.
- Business *B* is very busy, so it asks the Cloud provider to perform the operation. The Cloud provider, who only has access to the encrypted data set, finds the sum of $10 + 20$ and returns the answer 30.
- Business *B* decrypts the Cloud provider's reply and provides the government with the decrypted answer, 15.

Access Control in SaaS

In a Cloud computing consumption model, where users are accessing Cloud services from any Internet-connected host, network access control will play a diminishing role. The reason is that traditional network-based access controls are focused on protecting resources from unauthorized access based on host-based attributes, which in most cases is inadequate, is not unique across users, and can cause inaccurate accounting. In the Cloud, network access control manifests as Cloud firewall policies enforcing host-based access control at the ingress and egress points of entry to the Cloud and logical grouping of instances within the Cloud. This is usually achieved using policies (rules) using standard Transmission Control Protocol/Internet Protocol (TCP/IP) parameters, including source IP, source port, destination IP, and destination port.

In contrast to network-based access control, user access control should be strongly emphasized in the Cloud, since it can strongly bind a user's identity to the resources in the Cloud and will help with fine granular access control, user accounting, support for compliance, and data protection. User access management controls, including strong authentication, single sign-on (SSO), privilege management, and logging and monitoring of Cloud resources, play a significant role in protecting the confidentiality and integrity of your information in the Cloud. ISO/IEC 27002 has defined six access control objectives that cover end user, privileged user, network, application and information access control.

Similar to SaaS service monitoring, customers who are hosting applications on an IaaS platform should take additional steps to monitor the health of the hosted application. For example, if we are hosting an e-commerce application on an Amazon EC2 virtual Cloud, we should monitor the health of both the e-commerce application and the virtual server instances. The strategies of securing virtual servers are given next.

11.6 Securing Virtual Servers

The simplicity of self-provisioning new virtual servers on an IaaS platform creates a risk that insecure virtual servers will be created. Secure-by-default configuration needs to be ensured by following or exceeding available industry baselines. Securing the virtual server in the Cloud requires strong operational security procedures coupled with automation of procedures. Here are some recommendations by IT organizations.

Use a secure-by-default configuration: VM image must be hardened and used as a standard hardened image for instantiating VMs (the guest OS) in a public Cloud. A best practice for Cloud-based applications is to build custom VM images that have only the capabilities and services necessary to support the application stack. Limiting the capabilities of the underlying application stack not only limits the host's overall attack surface, but also greatly reduces the number of patches needed to keep that application stack secure.

Track the inventory of VM images and OS versions that are prepared for Cloud hosting: The IaaS provider provides some of these VM images. When a virtual image from the IaaS provider is used it should undergo the same level of security verification and hardening for hosts within the enterprise. The best alternative is to provide your own image that conforms to the same security standards as internal trusted hosts. Protect the integrity of the hardened image from unauthorized access.

Safeguard the private keys required to access hosts in the public Cloud: In general, isolation of the decryption keys from the Cloud where the

data is hosted is required, unless they are necessary for decryption. If an application requires a key to encrypt and decrypt for continuous data processing, it may not be possible to protect the key since it will be collocated with the application.

Include no authentication credentials in virtualized images except for a key to decrypt the filesystem key: We should not allow password-based authentication for shell access. For administration privileges (sudo *) or role-based access (e.g., Solaris, SELinux), passwords are mandatory.

Run a host firewall and open only the minimum ports necessary to support the services on an instance: The users should run only the required services and turn off the unused services (e.g., turn off FTP, print services, network file services and database services if they are not required).

Enable system auditing and event logging, and log the security events to a dedicated log server: The log server with higher security protection, including accessing controls needs to be isolated.

11.7 Cloud Security Controls

Cloud security architecture is effective only if the correct defensive implementations are in place. An efficient Cloud security architecture should recognize the issues that will arise with security management. The security management addresses these issues with security controls. These controls are put in place to safeguard any weaknesses in the system and reduce the effect of an attack. While there are many types of controls behind a Cloud security architecture, they can usually be found in one of the following categories.

Deterrent controls: These controls are intended to reduce attacks on a Cloud system. Much like a warning sign on a fence or a property, deterrent controls typically reduce the threat level by informing potential attackers that there will be adverse consequences for them if they proceed.

Preventive controls: It strengthens the system against incidents, generally by reducing if not actually eliminating vulnerabilities. Strong authentication of Cloud users, for instance, makes it less likely that unauthorized users can access Cloud systems, and more likely that Cloud users are positively identified.

Detective controls: Detective controls are intended to detect and react appropriately to any incidents that occur. In the event of an attack, a detective control will signal the preventive or corrective controls to address the issue. System and network security monitoring, including intrusion detection and prevention arrangements, are typically employed to detect attacks on Cloud systems and the supporting communications infrastructure.

Corrective controls: It reduces the consequences of an incident, normally by limiting the damage. They come into effect during or after an incident. Restoring system backups in order to rebuild a compromised system is an example of a corrective control.

Summary

Cloud computing is a nascent and rapidly evolving model, with new aspects and capabilities being announced regularly. In this chapter, we provide a comprehensive and timely look at the security issues w.r.t IaaS, Paas and SaaS services. Organizations that rely solely on a Cloud vendor's built-in security potentially expose their organization to unnecessary risk. This is particularly true for the credentials and secrets that proliferate in Cloud environments and automated processes. These secrets are dynamically created and assigned to provision, configure and manage hundreds of thousands of machines and microservices, but many are never secured. If they are compromised, these secrets and credentials can give attackers a crucial jumping-off point to achieve lateral access across networks, data and applications, and ultimately, provide access to an organization's most critical assets.

Keywords

Security management	Data security
IaaS security	PaaS security
SaaS security	

Objective type questions

1. Which of the following service provider provides the least amount of built in security ?

- | | |
|----------|----------------------|
| (a) SaaS | (b) PaaS |
| (c) IaaS | (d) All of the above |

2. Point out the correct statement:

- (a) Different types of Cloud computing service models provide different levels of security services
- (b) Adapting your on-premises systems to a Cloud model requires that you determine what security mechanisms are required and mapping those to controls that exist in your chosen Cloud service provider
- (c) Data should be transferred and stored in an encrypted format for security purpose
- (d) All of the above

3. Which of the following services that need to be negotiated in Service Level Agreements ?

- (a) Logging
- (b) Auditing
- (c) Regulatory compliance
- (d) All of the above

4. Point out the wrong statement:

- (a) You can use proxy and brokerage services to separate clients from direct access to shared Cloud storage
- (b) Any distributed application has a much greater attack surface than an application that is closely held on a LAN
- (c) Cloud computing don't have vulnerabilities associated with Internet applications
- (d) All of the above

5. Which of the following area of Cloud computing is uniquely troublesome ?

- (a) Auditing
- (b) Data integrity
- (c) e-Discovery for legal compliance
- (d) All of the above

6. Which of the following is operational domain of CSA ?

- (a) Scalability
- (b) Portability and interoperability
- (c) Flexibility
- (d) None of the above

7. Which of the following is considered an essential element in Cloud computing by CSA ?

- (a) Multi-tenancy
- (b) Identity and access management
- (c) Virtualization
- (d) All of the above

8. Which of the following is used for Web performance management and load testing ?

- (a) VMware Hyperic
 - (b) Webmetrics
 - (c) Univa UD
 - (d) Tapinsystems
9. Which of the following is application and infrastructure management software for hybrid multi-Clouds ?
- (a) VMware Hyperic
 - (b) Webmetrics
 - (c) Univa UD
 - (d) Tapinsystems
10. Which of the following is policy based XML security service by Cisco ?
- (a) Application Oriented Manager
 - (b) Application Oriented Networking
 - (c) Application Process Networking
 - (d) All of the above
11. Point out the wrong statement:
- (a) SOA eliminates the use of application boundaries, the traditional methods where security is at the application level aren't likely to be effective
 - (b) An atomic service cannot be decomposed into smaller services that provide a useful function
 - (c) XML security service may be found in Citrix's NetScaler 9.0
 - (d) None of the above
12. Which of the following is not a OASIS standard for SOA Security ?
- (a) Security Assertion Markup Language
 - (b) Synchronized Multimedia Integration Language
 - (c) WS-SecureConversation
 - (d) All of the above
13. Which of the following provides data authentication and authorization between client and service ?
- (a) SAML
 - (b) WS-SecureConversation
 - (c) WS-Security
 - (d) All of the above
14. Point out the wrong statement:
- (a) To address SOA security, a set of OASIS standards have been created
 - (b) WS-SecureConversation attaches a security context token to communications such as SOAP used to transport messages in an SOA enterprise
 - (c) WS-Trust is an extension of SOA that enforces security by applying tokens such as Kerberos, SAML, or X.509 to messages
 - (d) None of the above

15. Which of the following is web services protocol for creating and sharing security context ?

- | | |
|------------------------|--------------------------|
| (a) WS-Trust | (b) WS-Secure Conversion |
| (c) WS-Security Policy | (d) All of the above |

Objective type questions -answer

1:c 2:d 3:d 4:c 5:d 6:b 7:a 8:b 9:c 10:b 11:d 12:b 13:a 14:c 15:b

Review questions

1. How a Cloud service provider ensures data integrity during transmission (within the Clouds and on the way from/to the Cloud)?
2. How data and applications are separated from one customer data and applications from other clients?
3. How the providers apply laws and regulations that are applicable to Cloud computing?
4. Mention platforms which are used for large scale Cloud computing.
5. What is the difference in Cloud computing and computing for mobiles?
6. How user can gain from utility computing?
7. What are the security aspects provided with Cloud?
8. List out different layers which define Cloud architecture.
9. What does “EUCALYPTUS” stands for?
10. What is the requirement of virtualization platform in implementing Cloud?
11. Mention the name of some large Cloud providers and databases.
12. Explain the difference between Cloud and traditional datacenters?

Critical thinking questions

1. Search the literature for papers proposing a layered architecture for computing Clouds and analyze critically the practicality of each of these approaches.
2. Discuss means to cope with the complexity of computer and communication systems other than modularity, layering and hierarchy.
3. We know how a VMBK (Virtual Machine-Based Rootkit) could pose serious security problems. Give other examples when abstraction of a physical system could be exploited for nefarious activities.
4. Give examples of undesirable behavior of computing and communication system that can be characterized as phase-transitions. Can you imagine a phase-transition in a Cloud?

Bibliography

- [1] Chen H, Liu X, Xu H, Wang C, “A Cloud service broker based on dynamic game theory for bilateral SLA negotiation in Cloud environment”, *Int J Grid Distrib Comput*, Vol. 9, no. 9, 2018, pp. 251-268.
- [2] R. Gellman, “Privacy in the Clouds: Risks to privacy and confidentiality from Cloud computing”, *The World Privacy Forum*, 2009, Available at: <http://www.worldprivacyforum.org/>
- [3] Ohlman, B., Eriksson, A., Rembarz, R., “What Networking of Information Can Do for Cloud Computing”, *Proceedings of 18th IEEE International Workshops on Enabling Technologies: Infrastructures for Collaborative Enterprises*, Groningen, The Netherlands, June 29-July 1, 2009.
- [4] L.J. Zhang and Qun Zhou, “CCOA: Cloud Computing Open Architecture”, *IEEE International Conference on Web Services*, pp. 607-616, 2009.
- [5] Tim Mather, Subra Kumaraswamy, Shahed Latif, “Cloud Security and Privacy: An Enterprise Perspective on Risks and Compliance”, *Book published by O’ Reilly Media*, USA, 2009.
- [6] Ronald L. Krutz, Russell Dean Vines, “Cloud Security: A Comprehensive Guide to Secure Cloud Computing”, *Book published by Wiley Publishing Inc.*, 2010.
- [7] K. Vieira, A. Schulter, C. B. Westphall, and C. M. Westphall, “Intrusion detection techniques for Grid and Cloud Computing Environment”, *IT Professional Magazine*, *IEEE Computer Society*, Vol. 12, no. 4, pp. 38-43, 2010.
- [8] Marios D. Dikaiakos, Dimitrios Katsaros, Pankaj Mehra, George Pallis, Athena Vakali, “Cloud Computing: Distributed Internet Computing for IT and Scientific Research”, *IEEE Internet Computing Journal*, Vol. 13, no. 5, pp. 10-13, September 2009, DOI: 10.1109/MIC.2009.103.
- [9] A. Williamson, “Comparing Cloud computing providers”, *Cloud Comp. Journal*, Vol. 2, no. 3, pp. 3-5, 2009.



Taylor & Francis

Taylor & Francis Group

<http://taylorandfrancis.com>